

Cryptographic Protocol Analysis and Verification

UT Dallas Team 1

Nathaniel Simmons nis190000@utdallas.edu

Zarish Mehboob zxm200007@utdallas.edu

David Leung dal190004@utdallas.edu

Arturo Yundt-Pacheco aay200001@utdallas.edu

Sponsor: NSA, Ed Ziegler

Agenda

- Top Level Research Description
- Project Objectives
- Investigator Biographies
- Progress to Date
- Conclusions to Date
- Schedule and Deliverables
- Issues/Challenges
- Bibliography
- Acronyms
- Terms/Definitions

Top Level Research Description (Motivation)

- Cryptography is the keystone to the security of all computer networks
- Cryptographic protocols may not have the security properties they intend to provide
- Correctness of these protocols should be formally verified

Project Objectives

- Analyze/verify the correctness of the cryptographic protocol: BACnet/SC
 - We will use the CPSA tool from MITRE to accomplish this task
- Each security property the protocol intends to provide will be analyzed
- Findings will be documented in a report
- If flaws found:
 - Findings can be potentially be published
 - Remediations can be researched/proposed
 - If potential remediations are found, they can also be formally verified

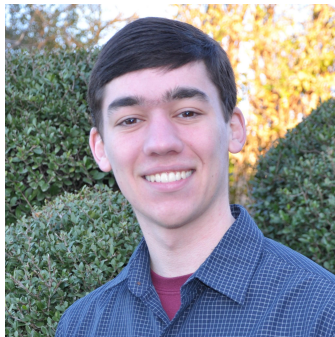
Biographies

Nate Simmons

UTD MS in CS Student

Cybersecurity research intern at
Lawrence Livermore National Lab

Research intern at UTD Software,
Systems, and Security lab



Arturo Yundt-Pacheco

UTD BS in CS Student



Zarish Mehboob

UTD MS in CS Student

Cybersecurity research intern at
Idaho National Lab



David Leung

UTD MS in CS Student

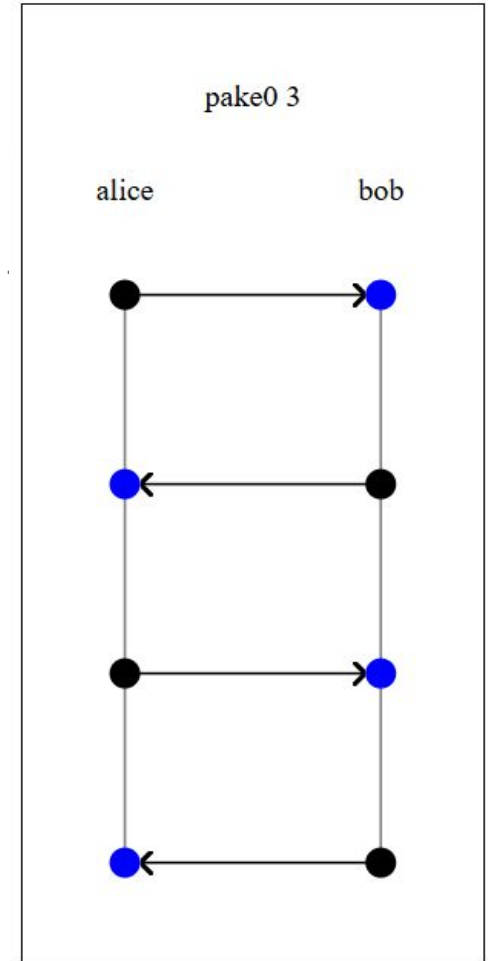


Research Plan

- CPSA Training
- BACnet Research
- Model/verify the protocol using CPSA
- Document Findings
- Research remediations for any flaws found



source: [zenatix](#)



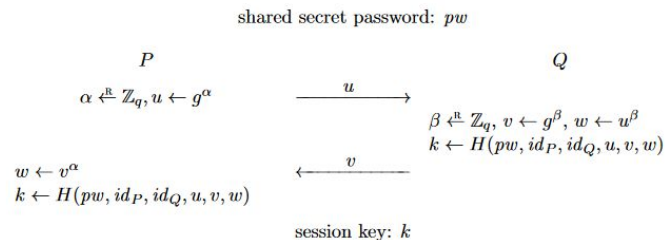
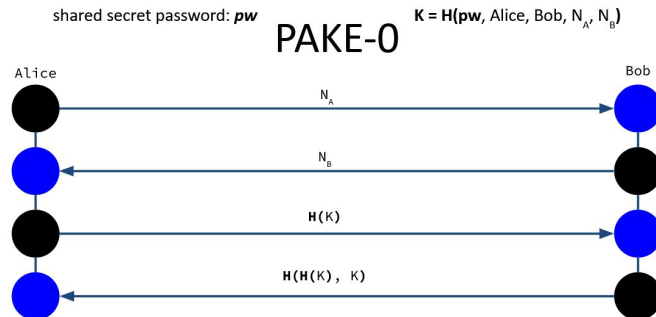
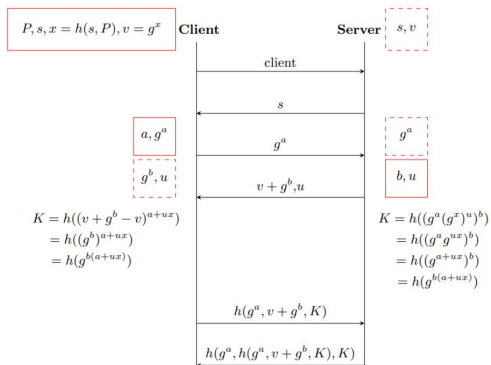
Cryptographic Protocol Shapes Analyzer (CPSA)

- The formal verification tool that will be used for analysis/verification
- Developed by Mitre
- Input the protocol and security goals
- Completes every possible execution
- Analysis of the output can reveal if the security goals are achieved

Summary of Results

- Modeled and verified protocols
 - Pake0
 - Pake1
 - SRP3
- Plan to model BACnet/SC

```
(defprotocol srp basic
  (defrole client
    ;; pwd salt x(hash) na nb
    (vars (c name) (a b u x rndx) (salt data) (gx locn))
    (trace
      (load gx "init")
      (stor gx (exp (gen) x))
      (send c)
      (recv salt)
      (send (exp (gen) a))
      (recv (cat (enc (exp (gen) b) (exp (gen) x)) u))
      ;; K = (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul l
      ;; h( g^(ab) + g^(bux)) = h( g^(ab + bux))
      (send (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)
      ;; h( g^a above K)
      (recv (cat (hash (exp (gen) a) ;; g^a
      (hash (exp (gen) a) (enc (exp (gen) b) (exp (gen) x)) (has
      (hash (hash (exp (gen) (mul a b)) (exp (gen) (mul b u x)))
    )
    (uniq-gen a x)
```



BACnet Overview

- Building Automation & Control Networks
 - e.g. HVAC, fire, security, lighting, etc.
- Objects
 - contain properties with information related to itself
- Services
 - requests sent from one BACnet device to another to perform an action

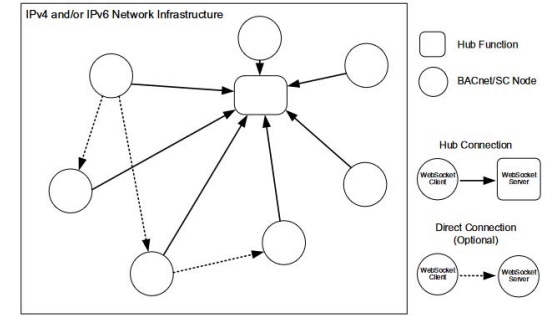


Figure AB-1. BACnet/SC Logical Network Topology

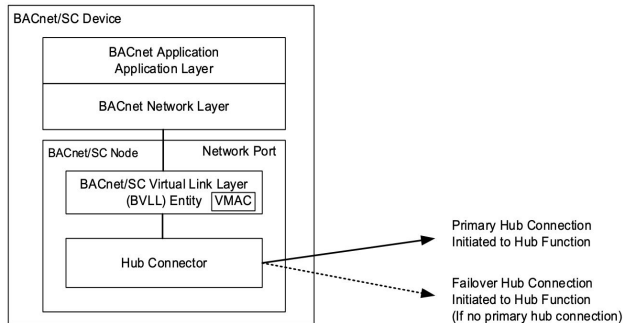
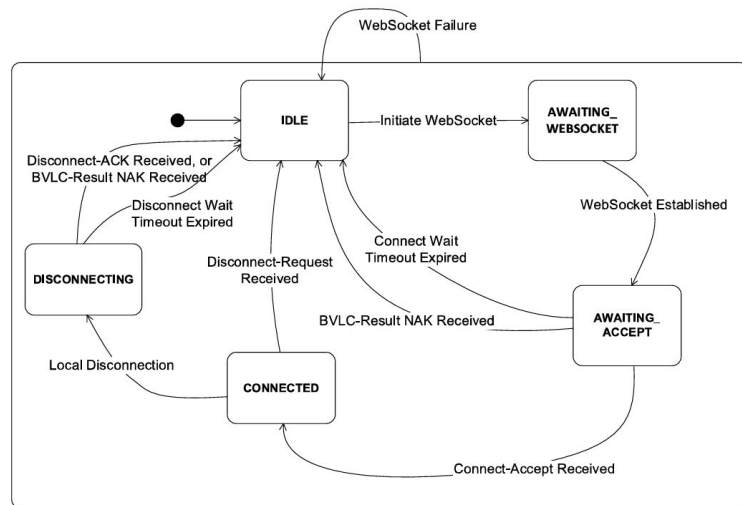


Figure AB-2. Example BACnet/SC Device

Object_Name	SPACE TEMP
Object_Type	ANALOG INPUT
Present_Value	72.3
Status_Flags	Normal, InService
High_Limit	78.0
Low_Limit	68.0

BACnet Secure Connect

- Addendum to base BACnet Protocol
 - Encrypted connection between devices
- Security Applied in Transport Layer
- Uses TLS secure WebSockets
 - peer authentication, message integrity, encryption



BACnet Layers

BACnet Application Layer							
BACnet Network Layer							
ISO 8802-2 (IEEE 802.3) Type 1		MS/TP	PTP	LonTalk	BVLL (Annex J)	BVLL (Annex U)	BZLL
ISO 8802-3 (IEEE 802.3)	ARCNET	EIA-485	EIA-232		IPv4	IPv6	Zigbee
							Secure Connect BVLL (Annex YY)
							WebSocket

Equivalent OSI Layers

Application
Network
Data Link
Physical

Progress to date

- CPSA training completed
- BACnet/SC paper acquired
- Preliminary analysis of BACnet/SC

Deliverables

- Midterm report/presentation - 10/25
 - A report that shares an update on progress and challenges
- Final report/presentation - 12/6
 - A report detailing the protocol and findings from the verification
 - If flaws found:
 - Potential publication of a research paper with the findings
 - If potential remediations found, the report/paper will include these as well
- CPSA code - 12/6

Issues and Challenges

- Lack of experience with formal verification
 - Training has proven effective
- Protocol Modeling
 - The specification is complex
 - Numerous addendums
 - Some vague parts in specification
- CPSA Limitations

Bibliography

BACnet A Data Communication Protocol for Building Automation and Control Networks. (2020). ASHRAE, 135–2020.

<https://webstore.ansi.org/standards/ashrae/ansiashrae1352020>

Acronyms

ANSI - American National Standards Institute

ASHRAE - The American Society of Heating, Refrigerating and Air-Conditioning Engineers

BACnet - Building Automation and Control Network

BACnet/SC - Building Automation and Control Network Secure Connect

CPSA - Cryptographic Protocol Shapes Analyzer

HVAC&R - Heating, Ventilation, Air Conditioning and Refrigeration

TLS - Transport Layer Security

Terms

ANSI - A standards institute facilitates the development of consensus standards in the US.

ASHRAE - A professional organization focused on HVAC&R and develop standards related to the field. The paper on BACNET was published in their journal in joint with ANSI.

BACnet - An open, standardized protocol used for communication between building automation and control systems.

BACnet/SC - A security protocol built on top of the BACnet communication protocol.

CPSA - A tool developed by MITRE used to analyze and evaluate the security properties of cryptographic protocols.

HVAC&R - A broad field encompassing the design, installation, operation, and maintenance of systems that control the temperature, humidity, and air quality in buildings.

TLS - A cryptographic protocol that provides security for communication over a computer network.

Q+A